MODULE 43 · DOMAIN 5 - OPERATIONAL EXCELLENCE AND AUTOMATION

DevSecOps: Pipeline Security and AI Evaluation

Scan code, dependencies and images, sign what you build, verify signatures before it runs, and gate AI releases on measured quality.

DOMAIN 5 of 5 EXAM WEIGHT 20% MODULE 43 of 52

admin@sthithapragna.com

Every stage **measures** something and can stop the release: vulnerabilities, provenance, or **model quality**.

Security checks along the pipeline

STAGE	CHECK	SERVICE
Pull request	SAST, SCA, IaC	Inspector code security
Build	SBOM and CVE scan	Inspector SBOM generator, ScanSbom API
Registry	Continuous image scanning	ECR enhanced scanning
Publish	Sign the artefact	AWS Signer, ECR managed signing
Run	Verify signature	Admission controller, Lambda code signing

ON THE EXAM

Inspector code security scans GitHub and GitLab repositories, GA June 2025.

ECR basic or enhanced scanning?

BASIC SCANNING

Operating system packages

- On push or on demand
- OS packages only
- No rescans as new CVEs appear
- No extra charge

ENHANCED SCANNING

Amazon Inspector

- Continuous rescanning
- OS and language packages
- New CVEs found in old images
- Findings in Inspector and Security Hub

THE TIEBREAKER

Language libraries, or a CVE published after the push: enhanced scanning.

Sign and verify

01

Signing profile

AWS Signer holds keys and certificates

02

Sign on push

ECR managed signing rule

03

Verify at admission

Notation with Kyverno or Ratify on EKS

04

Lambda

Code signing config, enforce mode

ON THE EXAM

Scanning says an artefact is safe; signing says it came from your pipeline.

Amazon Bedrock Evaluations

EVALUATION	MEASURES
Programmatic	Exact match, F1, BERT score
LLM as a judge	Correctness, completeness, harmfulness
Human	Your team or an AWS-managed team
RAG, retrieve only	Context relevance and coverage
RAG, retrieve and generate	Faithfulness, correctness
Bring your own responses	Models hosted anywhere

ON THE EXAM

Compare jobs side by side to decide whether a candidate beats the current model.

AI evaluation as a pipeline gate

01
Change
New model, prompt or knowledge base

02
Evaluate
Same test set, same metrics

03
Compare
Candidate against baseline

04
Promote or stop
Threshold decides

ON THE EXAM

Treat a prompt or model change like code: test it against a fixed set before release.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
New CVE in an old image, language libraries	ECR enhanced scanning
Fail the build before the image is pushed	Inspector SBOM scan in CodeBuild
Findings on developers' pull requests	Inspector code security
Only run images built by our pipeline	Signing plus admission verification
Is the new model or prompt as good?	Bedrock Evaluations against baseline
Model hosted outside Bedrock	Bring your own inference responses

ON THE EXAM

Scan for safety, sign for provenance, evaluate for quality.

> Fenwick Health stores 400 container images in Amazon ECR, mostly Python and Java services. Basic scanning runs on push.
>
> Security discovered that a critical library vulnerability published last month was never reported for images pushed earlier.

What should the solutions architect change?

A Rescan every image manually each week

B Enable Amazon GuardDuty Runtime Monitoring

C Turn on ECR enhanced scanning with continuous scanning

D Rebuild all images every night

◆ PAUSE AND DECIDE

What should the solutions architect change?

A Manual weekly rescans

Basic scanning still misses language libraries.

B GuardDuty Runtime

Detects threats at runtime, not package CVEs.

C Enhanced, continuous

Covers language packages and rescans as CVEs appear.

D Nightly rebuilds

Costly, and still does not report findings.

THE SIGNAL

Language libraries and newly published CVEs: ECR enhanced scanning.

> Fenwick Health wants images with critical vulnerabilities stopped in the CodeBuild stage, before they ever reach ECR.
>
> The check must use the same vulnerability data that Inspector uses for running workloads.

What should the solutions architect implement?

A. In CodeBuild, generate an SBOM with the Inspector SBOM generator, scan it with the Inspector ScanSbom API, and fail on critical findings

B. Rely on ECR enhanced scanning after push

C. Enable Amazon Macie on the artefact bucket

D. A Security Hub CSPM control

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A SBOM scan in CodeBuild

Checks before push, with Inspector's data, and fails the build.

B Enhanced scanning

Runs after the image is in ECR.

C Macie

Finds sensitive data, not CVEs.

D Security Hub CSPM

Checks configuration, not image contents.

THE SIGNAL

Stop it before the registry, with Inspector's data: SBOM scan in the build.

> Fenwick Health developers use GitHub. Security wants code flaws, vulnerable dependencies and Terraform misconfigurations reported on each repository, so developers see them before merging.
>
> Security also wants an organisation-wide view of the findings.

Which service should the solutions architect use?

A AWS Config with conformance packs

B Amazon GuardDuty

C ECR enhanced scanning

D Amazon Inspector code security, integrated with GitHub

◆ PAUSE AND DECIDE

Which service should the solutions architect use?

A **Config**
Evaluates deployed resources, not source code.

B **GuardDuty**
Threat detection, not code analysis.

C **ECR scanning**
Images only, after build.

D **Inspector code security**
SAST, SCA and IaC scans in GitHub, central findings.

THE SIGNAL

Code, dependencies and IaC, in the repository: Inspector code security.

> Fenwick Health's EKS clusters must run only container images built and pushed by its own pipeline. An engineer recently deployed an image pulled straight from a public registry.
>
> Security wants a cryptographic guarantee, with signing keys managed by AWS.

What should the solutions architect implement?

A ECR tag immutability

B ECR managed signing with an AWS Signer profile, and an admission controller on EKS that verifies signatures with Notation

C ECR enhanced scanning

D An IAM policy limiting who can push to ECR

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Tag immutability**
Stops tags being overwritten, not foreign images.

B **Sign and verify**
Unsigned images are refused at admission.

C **Enhanced scanning**
Finds CVEs, not provenance.

D **Push permissions**
Images from other registries bypass ECR entirely.

THE SIGNAL

Only our images may run, cryptographically: sign on push, verify at admission.

> Fenwick Health runs a clinical guidance assistant on a Bedrock knowledge base. Teams change prompts, models and documents every few weeks, and one change last quarter increased unsupported answers.
>
> Every change must now be proven no worse than production before it is released.

What should the solutions architect add to the pipeline?

A. A Bedrock guardrail with contextual grounding

B. CloudWatch latency alarms

C. A human review of five answers per release

D. A Bedrock RAG evaluation job on a fixed test set, comparing faithfulness and correctness against the production baseline

◆ PAUSE AND DECIDE

What should the solutions architect add to the pipeline?

A Guardrail

Filters at runtime; does not compare releases.

B Latency alarms

Speed, not answer quality.

C Five answers

Too small to detect a regression.

D RAG evaluation gate

Scores each change against the baseline before release.

THE SIGNAL

Prove a change is no worse before release: evaluation job against the baseline.

> Fenwick Health also runs a fine-tuned open-weight model on SageMaker AI endpoints. The team wants to score it with the same LLM-as-a-judge metrics used for its Bedrock models.
>
> Moving the model to Bedrock is not planned.

How should the solutions architect evaluate it?

A. Run Bedrock Evaluations with bring-your-own inference responses from the SageMaker model in the prompt dataset

B. Import the model into Bedrock first

C. Write a custom judge application on EC2

D. Use human evaluation only

◆ PAUSE AND DECIDE

How should the solutions architect evaluate it?

A Bring your own responses
Same judge and metrics, model stays where it is.

B Import to Bedrock
A migration the team has ruled out.

C Custom judge
Rebuilds a managed feature, and metrics differ.

D Human only
Not the same metrics, and slower.

THE SIGNAL

Evaluate a model hosted anywhere with Bedrock metrics: bring your own inference responses.

What to carry out of this module

- **Inspector code security** for repositories; **SBOM scan** in the build.
- **ECR enhanced scanning**: language packages, continuous rescans.
- **Sign and verify**: ECR managed signing, admission checks, Lambda code signing.
- **Bedrock Evaluations** as a release gate against a baseline.
- **Bring your own responses** for models hosted elsewhere.

> ON THE EXAM
>
> Scan for safety, sign for provenance, evaluate for quality.